

■ LAB 7

Analyse Dynamique d'une Application Android avec MobSF

Date: 06/05/2026

■ Objectif du laboratoire

Ce laboratoire a pour but de mettre en pratique l'analyse dynamique d'une application Android vulnérable en utilisant MobSF. Contrairement à l'analyse statique, ici l'application est exécutée dans un environnement contrôlé afin d'observer son comportement en temps réel : logs, trafic réseau et interactions système.

L'application utilisée est DIVA (Damn Insecure and Vulnerable App), conçue spécifiquement pour illustrer différentes failles de sécurité.

1. L'application DIVA

L'application DIVA (Damn Insecure and Vulnerable App) est une application Android conçue à des fins pédagogiques. Elle contient intentionnellement de nombreuses vulnérabilités pour permettre aux développeurs et testeurs de sécurité d'apprendre à identifier et corriger les failles.

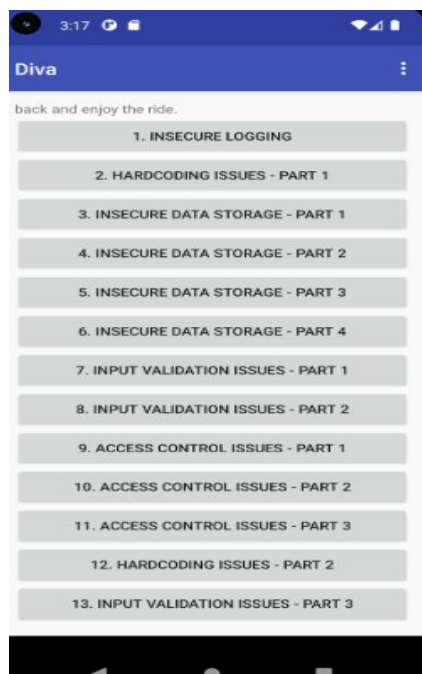


Figure 1: Interface principale de l'application DIVA affichant les différents modules de vulnérabilités.

2. Configuration de l'environnement

Pour réaliser une analyse dynamique avec MobSF, trois éléments doivent fonctionner ensemble:

- Un émulateur Android rooté (sans Google Play)
- L'outil MobSF (lancé via Docker)
- L'APK cible (DIVA)

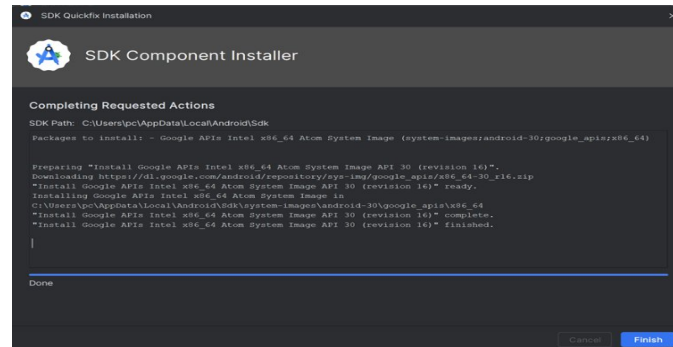


Figure 2: Installation des composants SDK Android via l'installateur de composants.

3. Démarrage de l'émulateur

Un émulateur Android rooté sans Google Play est essentiel pour MobSF. Le système doit être préparé avec les outils nécessaires incluant Frida pour l'instrumentation dynamique.



Figure 3: Configuration du Pixel 5 avec Android 11 (API 30) - Architecture x86_64.

Caractéristiques clés de l'émulateur:

- Appareil: Pixel 5
- Android: API 30 (Android 11)
- Architecture: x86_64
- Type: Google APIs (sans Play Store)

4. Installation et configuration de MobSF

MobSF (Mobile Security Framework) est installé via Docker pour assurer un environnement d'analyse isolé et reproductible. Le processus consiste à cloner le dépôt GitHub, puis à utiliser Docker pour télécharger et exécuter l'image.

4.1 Clonage du dépôt MobSF

```
PS C:\Users\pc\Documents> cd Mobile-Security-Framework-MobSF
PS C:\Users\pc\Documents\Mobile-Security-Framework-MobSF> |
```

Figure 4: Navigation vers le répertoire Mobile-Security-Framework-MobSF.

```
PS C:\Users\pc\Documents> git clone https://github.com/MobSF/Mobile-Security-Framework-MobSF.git
Cloning into 'Mobile-Security-Framework-MobSF'...
remote: Enumerating objects: 22239, done.
remote: Counting objects: 100% (47/47), done.
remote: Compressing objects: 100% (43/43), done.
Receiving objects: 10% (2374/22239), 78.36 MiB | 1008.00 KiB/s
```

Figure 5: Clonage du dépôt GitHub de MobSF avec la progression de téléchargement.

4.2 Téléchargement de l'image Docker

Une fois le dépôt cloné, l'image Docker de MobSF est téléchargée depuis le registre OpenSecurity. Cette image contient tous les composants nécessaires pour exécuter MobSF.

```
PS C:\Users\pc> docker pull opensecurity/mobile-security-framework-mobsf:latest
latest: Pulling from opensecurity/mobile-security-framework-mobsf
Digest: sha256:3b59941ac842e5c91668d4ffd385df8a9e6e565264ffd9d9538d880272ce2c69
Status: Image is up to date for opensecurity/mobile-security-framework-mobsf:latest
docker.io/opensecurity/mobile-security-framework-mobsf:latest
PS C:\Users\pc> |
```

Figure 6: Téléchargement de l'image Docker MobSF avec le SHA256 de vérification.

Commande Docker utilisée:

```
docker pull opensecurity/mobile-security-framework-mobsf:latest
```

Cette commande télécharge l'image 'latest' du registre Docker officiel d'OpenSecurity. Le digest SHA256 confirme l'intégrité et l'authenticité de l'image téléchargée.

5. Lancement de MobSF

Une fois Docker configuré et l'image téléchargée, MobSF démarre et expose son interface web sur le port 8000.

Commande de démarrage:

```
docker run -it --rm -p 8000:8000 -p 1337:1337  
opensecurity/mobile-security-framework-mobsf:latest
```

Ports d'écoute:

- Port 8000: Interface web de MobSF (<http://localhost:8000>)
- Port 1337: Serveur auxiliaire pour Frida et autres outils

6. Authentification à MobSF

MobSF requiert une authentification pour accéder à l'interface d'analyse. Les identifiants par défaut sont fournis lors de l'installation.

Champ	Valeur
Utilisateur	mobsf
Mot de passe	mobsf

Sign in to access

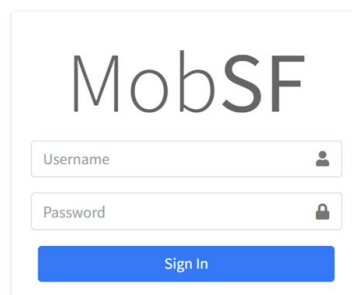
The image shows the MobSF login interface. At the top, it says "Sign in to access". Below this is the MobSF logo. There are two input fields: "Username" with a user icon and "Password" with a lock icon. A blue "Sign In" button is at the bottom.

Figure 7: Page d'authentification de MobSF.

7. Analyse statique de l'APK DIVA

MobSF effectue une analyse statique complète de l'APK, révélant les permissions, les vulnérabilités et les mauvaises configurations. Le rapport inclut un score de sécurité global.

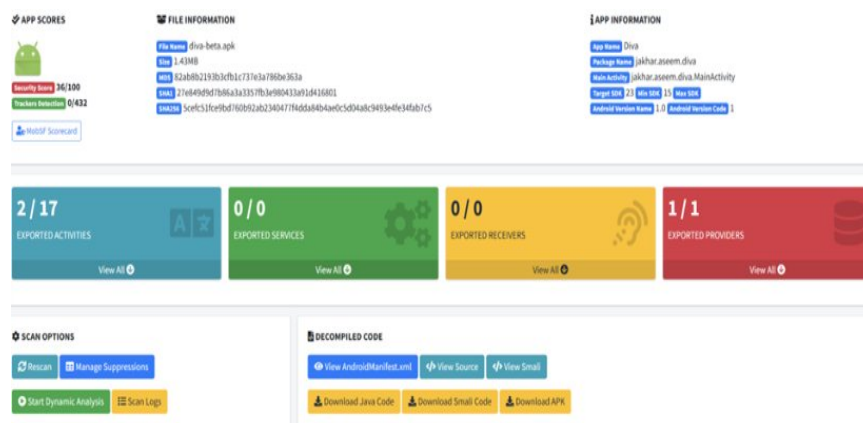


Figure 8: Rapport d'analyse statique montrant les scores de sécurité et les vulnérabilités détectées.

Éléments analysés lors du scan statique:

- Permissions demandées par l'application
- Activités et services exportés
- Certificats et signature
- Données sensibles en clair
- Chemins d'accès et stockage des données

8. Analyse dynamique avec MobSF

Une fois l'émulateur prêt et MobSF démarré, l'analyse dynamique lance l'application et capture en temps réel les logs, le trafic réseau et les interactions système.

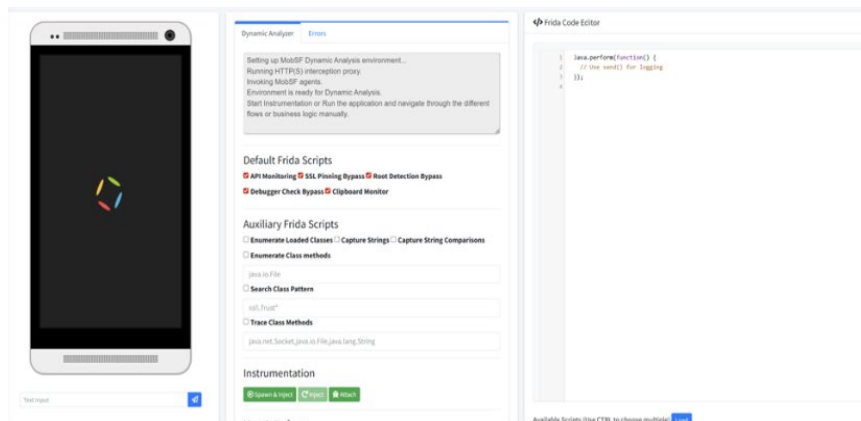


Figure 9: Interface de l'analyse dynamique avec accès à Frida et API Monitoring.

Capacités de l'analyse dynamique:

- Monitoring du trafic réseau en temps réel
- Capture des logs d'application
- Suivi des appels API système
- Interception des fonctions via Frida
- Inspection de la mémoire et des données stockées

9. Instrumentation dynamique avec Frida

Frida est un outil d'instrumentation dynamique qui permet d'intercepter des fonctions, d'analyser les appels internes et de modifier le comportement de l'application en temps réel. MobSF intègre Frida pour faciliter l'analyse avancée.



Figure 10: Interface Frida Code Editor avec les scripts disponibles pour l'analyse dynamique.

Scripts Frida disponibles:

- API Monitoring: Trace les appels API
- String Bypass: Analyse les chaînes de caractères
- SSL Pinning Bypass: Contourne le certificate pinning
- Clipboard Monitor: Capture les données du presse-papiers

10. Exécution de l'application dans l'émulateur

L'application DIVA est installée automatiquement et exécutée dans l'émulateur. Tous les événements, logs et interactions sont capturés par MobSF pour analyse.

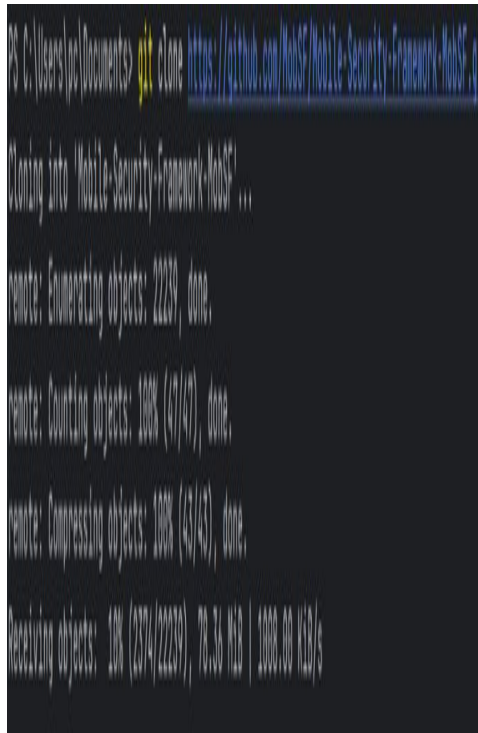


Figure 11: Application DIVA en exécution dans l'émulateur Pixel 5 avec Android 11.

11. Tests des vulnérabilités DIVA

L'application DIVA contient plusieurs modules pour tester différentes catégories de vulnérabilités. Chaque module est conçu pour illustrer une faille de sécurité spécifique.

Catégorie	Description
Insecure Logging	Données sensibles exposées dans les logs
Hardcoding Issues	Clés, tokens et secrets codés en dur
Insecure Data Storage	Données non chiffrées ou mal protégées
Input Validation	Failles d'injection et de validation
Access Control	Contrôle d'accès défaillant

12. Conclusion

L'analyse dynamique complète l'analyse statique. Tandis que l'analyse statique examine le code et la configuration sans exécution, l'analyse dynamique observe le comportement réel de l'application en environnement contrôlé. Cette approche combinée permet d'identifier des vulnérabilités complexes qui ne sont visibles qu'à l'exécution, notamment au niveau du réseau, des logs d'application et des interactions système.

MobSF offre une plateforme intégrée pour:

- Automatiser l'installation et le déploiement de l'APK sur l'émulateur
- Capturer et analyser le trafic réseau en temps réel (HTTP/HTTPS)
- Examiner les logs d'application et les événements système
- Utiliser Frida pour l'instrumentation dynamique avancée
- Générer des rapports détaillés et exploitables pour la remédiation

Ces capacités font de MobSF un outil indispensable pour les testeurs de sécurité, les développeurs et les équipes de sécurité cherchant à évaluer la robustesse et la sécurité des applications Android. L'approche pratique et basée sur l'automatisation de MobSF permet de réduire les délais d'analyse tout en améliorant la qualité des résultats.